

Security Assessment Report

Automated Authentication & Authorization Security Assessment

Target	Target 1
URL	http://127.0.0.1:5000
Assessment Type	Automated Access Control Security Testing
Generated	08 October 2026, 14:16:55

RBAC • JWT • Horizontal Authorization / IDOR • JWT Validation

1. EXECUTIVE SECURITY SUMMARY

TOTAL	PASSED	FAILED	SKIPPED	ERRORS
40	35	0	5	0
✓ OVERALL SECURITY RESULT: PASS				

2. SECURITY TEST COVERAGE

Security Category	Total	Passed	Failed
Authentication	8	7	0
Authorization	12	11	0
Horizontal Authorization / IDOR	12	10	0
JWT Validation	8	7	0

3. ASSESSMENT SCOPE

The assessment evaluated authentication enforcement, role-based authorization, horizontal authorization boundaries, vertical privilege separation, JWT validation, and protected API resource access using the configured security policy and resource ownership rules.

4. DETAILED SECURITY TEST RESULTS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0001	admin	Authorization	GET	/	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0002	user	Authorization	GET	/	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0003	admin	Authorization	GET	/api/products	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0004	user	Authorization	GET	/api/products	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0005	anonymous	Authentication	GET	/api/me	Control evaluated	401, 403	401	✓ PASS
AC-0006	invalid-token	JWT Validation	GET	/api/me	Control evaluated	401, 403	401	✓ PASS
AC-0007	admin	Authorization	GET	/api/me	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0008	user	Authorization	GET	/api/me	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0009	anonymous	Authentication	GET	/api/users/{user_id}	Control evaluated	401, 403	401	✓ PASS
AC-0010	invalid-token	JWT Validation	GET	/api/users/{user_id}	Control evaluated	401, 403	401	✓ PASS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0011	admin	Horizontal Authorization / IDOR	GET	/api/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0012	admin	Horizontal Authorization / IDOR	GET	/api/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0013	user	Horizontal Authorization / IDOR	GET	/api/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0014	user	Horizontal Authorization / IDOR	GET	/api/users/{user_id}	Control evaluated	401, 403, 404	403	✓ PASS
AC-0015	anonymous	Authentication	PATCH	/api/users/{user_id}	Control evaluated	401, 403	401	✓ PASS
AC-0016	invalid-token	JWT Validation	PATCH	/api/users/{user_id}	Control evaluated	401, 403	401	✓ PASS
AC-0017	admin	Horizontal Authorization / IDOR	PATCH	/api/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0018	admin	Horizontal Authorization / IDOR	PATCH	/api/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0019	user	Horizontal Authorization / IDOR	PATCH	/api/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0020	user	Horizontal Authorization / IDOR	PATCH	/api/users/{user_id}	Control evaluated	401, 403, 404	403	✓ PASS
AC-0021	anonymous	Authentication	GET	/api/orders/{order_id}	Control evaluated	401, 403	401	✓ PASS
AC-0022	invalid-token	JWT Validation	GET	/api/orders/{order_id}	Control evaluated	401, 403	401	✓ PASS

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0023	anonymous	Authentication	GET	/api/admin/users	Control evaluated	401, 403	401	✓ PASS
AC-0024	invalid-token	JWT Validation	GET	/api/admin/users	Control evaluated	401, 403	401	✓ PASS
AC-0025	admin	Authorization	GET	/api/admin/users	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0026	user	Authorization	GET	/api/admin/users	Control evaluated	401, 403, 404	403	✓ PASS
AC-0027	anonymous	Authentication	GET	/api/admin/users/{user_id}	Control evaluated	401, 403	401	✓ PASS
AC-0028	invalid-token	JWT Validation	GET	/api/admin/users/{user_id}	Control evaluated	401, 403	401	✓ PASS
AC-0029	admin	Horizontal Authorization / IDOR	GET	/api/admin/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0030	admin	Horizontal Authorization / IDOR	GET	/api/admin/users/{user_id}	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0031	user	Authorization	GET	/api/admin/users/{user_id}	Control evaluated	401, 403, 404	403	✓ PASS
AC-0032	anonymous	Authentication	DELETE	/api/admin/users/{user_id}	Control evaluated	401, 403	-	SKIP
AC-0033	invalid-token	JWT Validation	DELETE	/api/admin/users/{user_id}	Control evaluated	401, 403	-	SKIP
AC-0034	admin	Horizontal Authorization / IDOR	DELETE	/api/admin/users/{user_id}	Control evaluated	200, 201, 202, 204	-	SKIP

ID	ROLE	CATEGORY	METHOD	ENDPOINT	RULE	EXP.	ACT.	RESULT
AC-0035	admin	Horizontal Authorization / IDOR	DELETE	/api/admin/users/{user_id}	Control evaluated	200, 201, 202, 204	-	SKIP
AC-0036	user	Authorization	DELETE	/api/admin/users/{user_id}	Control evaluated	401, 403, 404	-	SKIP
AC-0037	anonymous	Authentication	GET	/api/admin/stats	Control evaluated	401, 403	401	✓ PASS
AC-0038	invalid-token	JWT Validation	GET	/api/admin/stats	Control evaluated	401, 403	401	✓ PASS
AC-0039	admin	Authorization	GET	/api/admin/stats	Control evaluated	200, 201, 202, 204	200	✓ PASS
AC-0040	user	Authorization	GET	/api/admin/stats	Control evaluated	401, 403, 404	403	✓ PASS

5. SECURITY FINDINGS

No security findings. No evaluated authentication or authorization control produced a failure during this assessment.

6. ASSESSMENT CONCLUSION

A total of **40** automated security tests were executed. **35** passed, **0** failed, **5** were skipped, and **0** produced errors.

✓ OVERALL SECURITY RESULT: PASS